

Case: rogue-service-account-privcreep

小さなデータ分析コンサルティング会社のBIアナリストが、1つの夜間自動処理 専用と文書化されているサービスアカウントを、明示的な代替クレデンシャルを 使って呼び出し、そのアカウントのアクセス権を使って自分自身をDomain Admins に追加する。これは無害な類似パターンではなく、正真正銘の、紛れもない権限 昇格である。このケースは、エージェントが、その後に起きたこと(グループ メンバーシップの変更)ではなく、明示的なクレデンシャル使用イベント自体を 異常の信号として特定できるか(サービスアカウントがそもそも対話的に使われた という点が、その後の結果とは独立して異常である)、それをデータ内の他の 場所にあるそのアカウント自身の正規の自動クレデンシャル使用と正しく区別 できるか、そして実際の権限変更までエスカレーションを追跡できるかを試す。

評価対象のエージェントへ: ここではなく、まず [AGENTS.md](#) を 開いてください。